

SEGURIDAD INFORMÁTICA Y CRIPTOGRAFÍA: TEMA 1

FUNDAMENTOS DE LA SEGURIDAD INFORMÁTICA

1. Introducción

OBJETIVO

Proteger los recursos valiosos de una organización.

¿QUE ES LO MÁS VALIOSO?

Los sistemas de información, definidos como un conjunto de recursos para que la información se pueda recoger, almacenar, procesar, mantener, usar, compartir...

OFICINA SIN PAPELES

Con la tercera generación de los ordenadores, MUCHA de la información de una empresa se almacena en soporte electrónico. Pero aún existe mucha más en soporte PAPEL.

¿LA APLICACIÓN DE MEDIDAS DE SEGURIDAD SUPONE FRUSTRAR OBJETIVOS DE NEGOCIO?

- CADA APLICACIÓN EN SU JUSTA MEDIDA.
- SEGURIDAD-FUNCIONALIDAD-FACILIDAD USO

MEDIDAS DE SEGURIDAD

Conjunto de prácticas destinadas a protegerse de los posibles riesgos sobre el sistema de información. Puede tratarse de medidas de prevención, de disuasión, de protección, de detección y reacción, o de recuperación.

2. La necesidad de aplicar mecanismos de Seguridad

DEFINICIONES

Seguridad de la información: Todas aquellas medidas preventivas y reactivas que permiten proteger la información buscando mantener la confidencialidad, la disponibilidad e Integridad de la misma.

¿QUÉ PUEDE OCURRIR, POR EJEMPLO, SI NO SE TOMAN MEDIDAS DE SEGURIDAD?

- Nuestras conversaciones por teléfono móvil son personales: nadie más debería poder escucharlas.
- Nuestros mensajes son privados: nadie debería tener acceso a ellos.
- Una compra solo interesa al vendedor y al comprador.
- La información pública en Internet debe estar al alcance de todos.

Aunque tomemos medidas de seguridad, no sabemos si las personas con las que nos comunicamos las toman. Estas medidas también afectan al receptor.

La información se puede catalogar en tres niveles:

- BASICA
- MEDIA

- ALTA

En base a ese nivel, se establecen las medidas de seguridad a aplicar.

¿CÓMO SABEMOS SI CUMPLIMOS LOS REQUISITOS DE SEGURIDAD NECESARIOS?

Mediante Auditorías de seguridad: Es la revisión y examen de los registros y actividades del sistema para verificar la idoneidad de los controles del sistema, asegurar que se cumplen la política de seguridad y los procedimientos operativos establecidos, detectar las infracciones de seguridad...

3. Elementos a proteger

Cuatro grandes grupos:

- EQUIPOS (ACTIVOS).
- SOFTWARE (APLICACIONES).
- INFORMACIÓN (DATOS).
- COMUNICACIONES

EQUIPOS

- Evitar la sustracción del equipo o de alguno de sus componentes
- No podemos evitar que los equipos portátiles salgan de las empresas, pero debemos cifrar esos equipos y que sus contraseñas estén actualizadas.
- No se pueden introducir nuevos equipos no autorizados.
- Aplicaremos mantenimiento preventivo para evitar averías.
- Identificaremos aquellos equipos con posibilidad de grabar información.

SOFTWARE

Intentarán instalarse otras aplicaciones ajenas:

- Intencionadamente. El usuario lanza un instalador del programa que ha descargado de Internet o lo trae de casa en un CD/USB.
- Inocentemente. El usuario entra en una página pirata que hace la descarga sin que lo sepa, o introduce un CD/USB que desconoce que está infectado por un virus.

Medidas de seguridad:

- Antivirus.
- A la hora de crear un usuario, evitar que tenga privilegios de administración del sistema.
- Desactivar el mecanismo de autoarranque de aplicaciones desde CD o USB.

INFORMACIÓN (DATOS)

- Todos los equipos deben estar protegidos contra software malicioso que pueda robar datos o alterarlos.
- El almacenamiento debe ser redundante.
- El almacenamiento debe ser cifrado.

COMUNICACIONES

- Almacenamiento distribuido. Importante la seguridad en las comunicaciones.
- Control de las comunicaciones.

- Evitar correos maliciosos.
- Control en el acceso de teletrabajo.

4. Definiciones

ACTIVOS

Cualquier componente o funcionalidad de un sistema de información susceptible de ser atacado, con consecuencias para la organización.

Los activos incluyen: información, datos, servicios, aplicaciones, equipos...

PROCESO: Conjunto organizado de actividades que se llevan a cabo para producir un producto o servicio, implica recursos y da lugar a un resultado.

PROCESO DE SEGURIDAD: Método que se sigue para alcanzar los objetivos de seguridad de la organización.

RIESGO: Estimación de que una amenaza se materialice sobre uno o más activos causando daños o perjuicios a la organización.

ANÁLISIS DE RIESGO: La utilización de la información disponible para identificar peligros y estimar los riesgos.

GESTIÓN DE RIESGO: Conjunto de actividades coordinadas para dirigir y controlar una organización con respecto a los riesgos.

INCIDENTES DE SEGURIDAD: Suceso inesperado o no deseado con consecuencias en detrimento de la seguridad del sistema de información. La diferencia entre un riesgo y un incidente es que el riesgo aún no se ha producido, y el incidente si se ha producido.

GESTIÓN DE INCIDENTES: Plan de acción para atender a las incidencias que se den.

TIPOS DE SEGURIDAD

- Seguridad física/Lógica.
- Seguridad Activa/Pasiva.

SEGURIDAD FÍSICA: La seguridad física cubre todos los riesgos asociados a los equipos informáticos.

- Amenazas:
 - Desastres naturales.
 - Robos.
 - Fallos de suministros.

SEGURIDAD LÓGICA: La seguridad lógica se refiere a las distintas aplicaciones que ejecutan en cada uno de los equipos informáticos (software).

- Amenazas:
 - Virus, troyanos y malware.
 - Pérdida de datos.
 - Ataques a las aplicaciones de servidores.

SEGURIDAD PASIVA: La seguridad pasiva son todos los mecanismos que, cuando sufrimos un ataque, nos permiten recuperarnos razonablemente bien.

SEGURIDAD ACTIVA: La seguridad activa intenta protegernos de los ataques mediante la adopción de medidas que protejan los activos de la empresa.

CONFIDENCIALIDAD: Propiedad o característica consistente en que la información ni se pone a disposición, ni se revela a individuos, entidades o procesos no autorizados.

Para garantizar la confidencialidad, es necesario aplicar una serie de mecanismos que garanticen la identidad de quién accede:

- **Autenticación:** La entidad es quien dice ser o bien garantiza la fuente de la que proceden los datos.
- **Autorización:** Proceso por el que se capacita a un usuario o sistema a acceder a cierta información o recursos.
- **Cifrado:** Método que permite aumentar la seguridad de un mensaje o de un archivo mediante la codificación del contenido, de manera que sólo pueda leerlo la persona que cuente con la clave para decodificarlo.

INTEGRIDAD: El objetivo de la integridad es que los datos queden almacenados tal y como espera el usuario, que no sean alterados sin su consentimiento.

DISPONIBILIDAD: La disponibilidad intenta que los usuarios puedan acceder a los servicios con normalidad en el horario establecido.

NO REPUDIO: Ante una relación entre dos partes, intentar evitar que cualquiera de ellas pueda negar que participara en esa relación. Dos tipos:

- No repudio del usuario.
- No repudio del sistema.

CONTABILIZACIÓN (ACCOUNTING): Información interna que los sistemas generan acerca de su comportamiento. Se usa para:

- Revisar dimensionamiento de los equipos.
- Comprobar eficacia de las medidas de seguridad.

TRAZABILIDAD: Propiedad o característica que consiste en que las actuaciones de una entidad pueden ser imputadas únicamente a dicha entidad.

EXTREMO A EXTREMO (e2e): La seguridad debe controlarse en el origen y destino de los datos y en el canal de comunicación utilizado entre origen y destino:

- Controlaremos que en el origen y en el destino ni equipo ni las aplicaciones se hayan modificado.
- Limitaremos el acceso al canal de comunicación y cifraremos la información.

VULNERABILIDAD: Es un defecto de una aplicación que puede ser aprovechado por un atacante. Tres tipos:

- Vulnerabilidad reconocida por el suministrador de la aplicación.
- Vulnerabilidad reconocida por el suministrador, pero aún no hay un parche.
- Vulnerabilidad no reconocida por el suministrador.

MALWARE Y EXPLOIT: Software programado con el objetivo de tomar el control del ordenador (exploit), o realizar cualquier actuación no autorizada aprovechando una vulnerabilidad existente. Tipos de Malware:

- Virus.
- Gusanos.
- Troyanos.

5. Estructuras básicas de Seguridad Informática

Los responsables de control de acceso y la planificación de recuperación de desastres constituyen el grupo básico de protección de la información.

Sistema de gestión de la seguridad de la información (SGSI): Sistema de gestión que, basado en el estudio de los riesgos, se establece para crear, implementar, supervisar, revisar, mantener y mejorar la seguridad de la información.

POLÍTICA DE SEGURIDAD: Conjunto de directrices que rigen la forma en que una organización gestiona y protege la información y los servicios que considera críticos.

ASPECTOS ORGANIZATIVOS DE SEGURIDAD: Estructura organizativa de gestión encargada de iniciar y controlar toda la implementación de la Seguridad de la Información.

- Comité de Gestión de Seguridad de la Información
- Coordinación de la Seguridad de la Información

Funciones del Comité de Gestión de Seguridad de la Información:

- Identificar las metas de la seguridad de información.
- Formular, revisar y aprobar la política de Seguridad de la Información.
- Proveer direcciones claras.
- Facilitar todos los recursos necesarios para llevar a cabo la Seguridad de la Información.

Funciones de la Coordinación de la Seguridad de la Información:

- Asegurar que las actividades de seguridad son acorde con la política de seguridad establecida.
- Identificar como se debe manejar los no cumplimiento.
- Aprobar las metodologías y los procesos.
- Identificar todos los cambios de amenazas y exposición de la información.

CLASIFICACIÓN Y CONTROL DE ACTIVOS: Es preciso identificar a los responsables de los activos de información importantes. Estos son los responsables de su mantenimiento. Algunos activos:

- Activos de información.
- Activos de software.
- Activos físicos.
- Servicios.
- Personas.

CONTROL DE ACCESOS: Gestión de cuentas de usuarios, contraseñas, permisos.

CONFORMIDAD: En este aspecto se contemplan todos los aspectos legales que han de asumir/emplear los participantes en el SGSI:

- Aspectos legales.

- Firmas digitales.
- Política de firma electrónica.
- Clasificación de la información.

SEGURIDAD LIGADA AL PERSONAL: Jornadas formativas y de concienciación al personal sobre la importancia de la seguridad.

SEGURIDAD FISICA Y DEL ENTORNO: Medidas de seguridad perimetrales físicas.

DESARROLLO Y MANTENIMIENTO DE SISTEMAS: Medidas de seguridad y estructura organizativa aplicable a las unidades de desarrollo.

GESTION DE COMUNICACIONES Y OPERACIONES: Establece las medidas de seguridad, procedimientos y operaciones establecidas para garantizar una correcta y segura manera de realizar las operaciones en el procesamiento de información.

GESTION DE CONTINUIDAD DEL NEGOCIO: Conjunto de directrices de cómo una organización debe recuperar y restaurar sus funciones críticas después de una interrupción no deseada.

- Análisis de riesgos.
- Análisis de impacto al negocio.
- Equipo de respuesta a Emergencias TI.
- Equipo de investigación forense.

6. Seguridad Pasiva

CENTRO DE PROCESO DE DATOS: Se recomienda una centralización del Centro de proceso de datos, porque así conseguimos:

- Ahorrar en costes de protección y mantenimiento.
- Optimizar las comunicaciones entre servidores.
- Aprovechar mejor los recursos humanos del departamento de informática.

CENTRO DE PROCESO DE DATOS

I. Protección del CPD.

- Ubicación física con poca probabilidad de accidentes naturales.
- En las primeras plantas del edificio.
- Accesos por varias calles, y con pasillos amplios.
- Acceso a la sala controlado.
- En las paredes, pintura plástica y falso suelo/techo.

II. Aislamiento del CPD.

- Aislamiento de la temperatura.
- Aislamiento de la humedad.
- Aislamiento de interferencias electromagnéticas.
- Aislamiento de ruido.

III. Ventilación del CPD.

- No suelen tener ventanas. Precisa ventilación específica
- Temperatura adecuada 22°C.
- Configuración pasillo caliente/pasillo frío.

IV. Suministro eléctrico y comunicaciones CPD.

- Diferenciar el servicio eléctrico que alimenta al CPD del que alimenta a la empresa.
- Redundancia en el suministro eléctrico.
- Existencia de sistemas electrógenos por combustible.
- En comunicaciones, tener dos proveedores, con tecnologías diferentes.

V. Control de acceso al CPD.

Importante tener controlado el acceso al CPD. Hay que evitar por todo lo posible:

- Que se lleven algo del CPD.
- Que dejen algo en el CPD.

CENTRO DE RESPALDO: Necesidad de tener un centro de respaldo que ofrezca los mismos servicios esenciales que el CPD.

SAI/UPS: Conjunto de baterías que alimentan una instalación eléctrica. El SAI está enchufado a la corriente eléctrica y actúa como puente. En el caso que se produzca una caída de la red eléctrica, las baterías entran en acción, haciendo que los equipos continúen funcionando.

• Tipos de SAI:

- En estado de espera
- En línea

• Monitorización de los SAI

• Triggers de los SAI.

• Mantenimiento de los SAI.

ALMACENAMIENTO: La información es la parte más importante de una organización:

- El hardware se puede volver a comprar.
- Un informático puede ser reemplazado por otro.
- Si un software se corrompe. Puede volver a ser reinstalado.

Para mejorar el almacenamiento:

- Comprar los mejores discos del mercado en cuanto a calidad y velocidad.
- Uso de servidores especializados en almacenamiento.
- Replicar la información.
- Servicios de respaldo.

Rendimiento y redundancia. Información redundada:

- RAID 0.
- RAID 1. (Agrupados por parejas).
- RAID 5. Usa paridad para obtener información adicional y se hace striping entre los discos conectados.

Almacenamiento en red.

- NAS. Network Attached Storage. Se comparte una parte del disco en red.

- SAN. Storage Area network. Estructura hardware especializada en almacenamiento. Torres de disco con configuración RAID.

Almacenamiento en la nube y p2p.

- Almacenamiento en la nube.
 - ♣ Primera Generación. Megaupload, Fileserver ...
 - ♣ Segunda Generación. DropBox, Icloud ...
- P2p (peer to peer). Emule, torrent ...

Ventajas e inconvenientes:

- Datos fuera de la organización. Acceso desde diferentes situaciones.
- La empresa proveedora del servicio encargada de las copias de seguridad.
- Acceso rápido, y no ocupamos ancho de banda de nuestra compañía.
- Perdemos el control sobre el acceso a nuestra información.

Backup de datos.

- Copias de seguridad.
 - o De datos.
 - o De sistemas.
- Objetos a salvar:
 - o Ficheros.
 - o Sistemas complejos (Bases de datos).
- Dispositivos locales y remotos de almacenamiento.
 - o Mismo disco.
 - o Disco distinto.
 - o Disco duro externo.
 - o Cintas magnéticas (mejor opción).
- Tipos de copias:
 - o Completa.
 - o Diferencial.
 - o Incremental.
- Imagen del sistema:
 - o Ventaja. Tiempo de instalación.

7. Seguridad Activa

SISTEMA OPERATIVO Y APLICACIONES

- Impedimentos físicos:
 - o Candados o dispositivos que eviten la apertura de las carcasas.
 - o Bloqueo de la BIOS con password.
- Autenticación en el sistema operativo:
 - o Usuario/Password.
 - o Tarjetas
 - o Biometría
- Elevación de privilegios:
 - o Dar permisos de administrador a usuarios del sistema. Puede ser de carácter temporal o permanente.

- Cuotas:
 - Limitaciones asociadas a los usuarios conectados.
- Actualizaciones y parches:
 - Actualización: Incorpora nuevas utilidades y acciones en el sistema.
 - Parche: Corrige errores y bugs detectados en el sistema.
- Antivirus:
 - Software específico que vigila constantemente lo que ocurre en una máquina.
- Monitorización:
 - Revisión y vigilancia para que el sistema funcione correctamente.
 - Revisar logs
 - Revisar la ocupación del sistema.
 - Sincronizar copia de logs en otra máquina.
- Aplicaciones web. Importante monitorizar y controlar los accesos de:
 - La máquina que soporta la aplicación web.
 - Si se ejecuta en hosting, confiar en el proveedor, y exigirle ANS.
 - Intentar controlar que el acceso entre el cliente web y el servidor web sea seguro.
 - La máquina cliente puede haber sido hackeada.
- Cloud computing:
 - IAAS: Infrastructure as a service. Nos proporcionan el hardware, y nosotros lo gestionamos por completo.
 - SAAS: Software as a service. Nos proporcionan el software necesario, y no nos preocupamos de nada.

ACCESO A REDES

- Protección frente a los ataques que vengan a través de la red.
- Protección física del switch y del resto de componentes electrónicos.
- Protección lógica de los componentes electrónicos.
- Habilitar/deshabilitar los puertos de los switches.
- Identificar los equipos que acceden a través de cada boca, y los puertos a los que puede acceder.
- Definiciones de VLANES.
 - VLAN: Grupo de puertos de un switch que aislamos del resto.
 - Ventajas de las VLANES:
 - Mejora rendimiento y seguridad.
 - Si ocurre un problema, afecta a una VLAN, no al resto.
 - Un exceso de tráfico afecta a todas.
 - Las VLANES pueden necesitar acceder a otros sitios. Para ello hablamos de las VLANES ETIQUETADAS. El puerto que conecta la VLAN etiqueta al paquete de datos, y ya puede compartir enlace con otras VLANES.
- Redes inalámbricas.
 - WLAN. Facilita la posibilidad de enlaces no autorizados, a través de los puntos de acceso.
 - Medidas físicas:
 - Proteger el Access point físicamente.

- Proteger el Access point lógicamente.
 - Controlar los clientes autorizados a conectar.
 - Separación de grupos de usuarios de la red.
 - Encriptar la comunicación entre al Access point y el cliente.
- Asociación y transmisión.
 - Asociación. Fase en la que el equipo se conecta a un SSID a través de un AP.
 - Transmisión. Fase en la que comienza a intercambiarse información entre el equipo y el AP.
- Cifrados WEP, WPA y WPA2.
 - WEP: Clave sencilla de encriptación.
 - WPA/WPA2: Algoritmos más seguros. Claves más grandes y algoritmos más complejos. Cada cierto tiempo, cliente y AP renegocian una nueva clave
- WPA empresarial. RADIUS.
 - En la LAN, existe un servidor RADIUS que tiene asociado una serie de usuarios/contraseñas de acceso.
 - Los Access Point están conectados a ese servidor.
 - Los Access Point ejecutan un software cliente RADIUS, capaz de formular preguntas y analizar las respuestas.
 - El Servidor RADIUS tiene una lista de las IP de los Access Point con derecho a preguntarle.
- VPN. Acceso a la red corporativa a través de internet, o cualquier otra red no segura.

Pasos que realiza una VPN:

 - Autenticación del cliente VPN.
 - Establecer un túnel a través de internet.
 - Proteger el túnel.
 - Liberar el túnel. Finalizar la conexión.

CONTROL DE REDES

Tres técnicas:

- Monitorización del tráfico. Medidas que se toman respecto al tamaño y número de paquetes enviados entre los puertos.
- Análisis del tráfico. Captura los paquetes que circulan por un interfaz, se leen y analizan.
- Sonda: Equipo de red programado para comportarse como un equipo normal, pero lo que hace es testear el estado del servicio.

Sirven para detectar:

- Ataques de tipo broadcast.
- Ataques de tipo Dos (Denial of service).

Captura de conversaciones. Tres posibilidades:

- Conseguir el control de uno de los extremos de la conexión.
- Interceptar la conexión desde algún equipo de red por donde pasen los paquetes.
- Conexión de un hub sobre el puerto a vigilar y estudiarlo.
- Firewall.
 - Software especializado que se interpone entre las aplicaciones y el software de red para hacer un filtrado de paquetes.
 - Funcionamiento:
 - La tarjeta de red recibe el paquete y lo identifica. Lo pasa al firewall para que decida si es seguro y lo pasa a la aplicación o no.
- Proxy.
 - Servicio de red que hace de intermediario en un determinado protocolo.
 - El proxy más habitual es el proxy HTTP.
 - Ventajas:
 - Seguridad para el software cliente.
 - Rendimiento.
 - Anonimato.
 - Acceso restringido.
 - Tipos de proxy:
 - Explícito
 - Transparente
 - Web 7.
- AntiSpam.
 - Software especializado en evitar correos electrónicos no deseados (spam).
 - Funcionamiento:
 - Se analiza la cabecera del mensaje, para ver si el origen está en alguna lista negra.
 - Se analiza el contenido del mensaje, buscando palabras con poca relación con la actividad de la empresa.
 - Autoaprendizaje. Si se define un correo como spam, se memoriza.
 - Frente a un spam el antispam puede:
 - Bloquearlo.
 - Dejarlo pasar, pero con aviso de correo sospechoso.
 - Dejarlo pasar como un nuevo correo, y con el texto antiguo en adjunto.

8. Hackers. Tipos de Hackers

Hacker: Personas que realizan accesos remotos no autorizados a los sistemas, con diferentes propósitos.

- Hacker de sombrero blanco: Usan sus habilidades informáticas para proteger sistemas frente ataques.
- Hacker de sombrero negro o crackers: Usan sus habilidades informáticas para romper, colapsar o robar información de los sistemas.
- Hacker de sombrero gris: Tienen las mismas intenciones que el hacker del sombrero negro, pero secuestran la información y se puede recuperar.
- Hacker de sombrero dorado: Usan sus habilidades informáticas para probar las vulnerabilidades de los sistemas.

Otras definiciones:

- Phreaker. Hacker de teléfono.
- Lamer o script-kiddie: Persona sin habilidades técnicas que intenta hackear.
- Newbie: Novato.

Algunas Herramientas de hacking ético:

- NMAP (Network Mapper): Detector de puertos.
- Wireshark: Analizador de paquetes de red.
- Metasploit: Analizador de vulnerabilidades de sistemas y redes.
- OWASP Zed: Analizador de vulnerabilidades de aplicaciones web.
- John the Ripper: Rompe contraseñas mediante ataques de fuerza bruta o diccionarios.

9. Reconocimiento de amenazas. Contramedidas

Objetivo de la amenaza: Dañar la integridad de los datos del sistema, provocar incendios o destrucción de la instalación.

Origen de la amenaza: Diverso origen. Acciones de empleados de confianza, hackers o mala actuación de los responsables del sistema.

Ejemplos de sabotajes:

- Destruir hardware o instalaciones.
- Implantación de código malicioso para destruir datos o programas.
- Introducción de datos incorrectos.
- Pérdida de capacidad física o infraestructura.

Ataques TCP/IP. MITM

Ataque MITM: (Man In The Middle). Se coloca un dispositivo entre una comunicación entre dos equipos, analizando los paquetes que pasan por él. Puede leerlo, alterarlo o interceptarlo.

Formas de realizar el ataque:

- Por hardware.
- Por software.

Ataques conocidos:

- Envenenamiento ARP. Obtenemos la MAC asociada a una IP y se suplanta.

Contramedidas:

- Uso de tablas ARP estáticas, renunciando al DHCP.

- Control de los accesos a la red.
- Uso de protocolos seguros, con PKI (Clave pública).
- Introducir un NIPS (Network Intrusion Prevention System) en la red.

Ataques Wifi

Fáciles de atacar, al estar muy extendidas y no ser necesario entrar en las instalaciones para acceder.

Contramedidas.

- Evitar el uso de cifrado WEP.
- Usar cifrado WPA o WPA2.
- Reducir la potencia del Access Point.
- Habilitar listas de MAC autorizadas en cada Access Point.

Ataques Web

Aplican protocolo cliente/servidor.

Contramedidas:

- Precaución en la programación de las aplicaciones.

Tipos de Ataques:

- Suelen usar combinaciones de ataques.
- Más conocido y exitoso: SSLStrip. Activa un MITM mediante ARP, y procesan tanto las peticiones HTTP como HTTPS.

Ataques Proxy

Intentan saltarse las limitaciones establecidas por un proxy. La trampa consiste en instalarse un proxy, de forma que el navegador pasa por él.

Contramedidas:

- Formar a los usuarios sobre el riesgo de saltarse el proxy, al:
 - Pasar por máquinas que desconocemos.
 - Poder saturar la infraestructura interna de red.
- Evitar que los usuarios puedan instalarse software.

10. Buenas Prácticas

Aspectos fundamentales:

- Localización de los activos a proteger.
- Actualización de los informes de seguridad.
- Revisión de los logs del sistema.
- Revisión de los equipos conectados.
- Revisión de los usuarios activos.

Tipos de gestión a considerar:

- Gestión de copias de seguridad.
- Gestión de incidentes de seguridad.

- Gestión de la monitorización.
- Gestión de contraseñas.
- Gestión de usuarios.

SEGURIDAD INFORMÁTICA Y CRIPTOGRAFÍA: TEMA 2

CRIPTOGRAFÍA DE CLAVE SECRETA

1. Introducción

La información es poder

NECESIDAD: Compartir esa información sólo con quien yo quiero.

RIESGOS: Escucha en los medios actuales:

- Voz por telefonía.
- Mensajería electrónica.
- Datos por línea digital.

Técnicas empleadas para evitar ser espiados (criptográficas):

- CIFRADO CESAR.
- CIFRADOS (CLAVE PÚBLICA).

La criptografía fusiona las matemáticas, la informática y la telemática.

2. Criptografía

Cripto: Ocultar.

Graphos: Escribir.

Criptografía: El arte y la técnica de crear mensajes codificados con procedimientos o claves secretas con el objeto de que no pueda ser descifrado salvo por la persona a quien está dirigido o que detenta la clave.

Elementos indispensables:

- Algoritmo
- Clave

Usos de la criptografía.

- En la autenticación. (Certificado electrónico).
- En la confidencialidad. (Encriptación de mensajes).
- En la integridad. (Firmado de documentos).
- No repudio o vinculación. (Identificación y time stamping).

Tipos de criptografía.

- **Criptografía simétrica:** Método en el cual se emplea la misma clave para encriptar y descifrar mensajes.
- **Criptografía asimétrica:** Es un método en el cual son empleadas dos claves, una pública y otra privada. A la clave pública cualquier persona puede acceder, mientras que a la privada solo tiene acceso su propietario.

3. Criptografía simétrica o de clave secreta

Tipos:

- **Criptografía simétrica de bloque:** Se caracteriza por el uso de bloques de 64 o 128 bits.
- **Criptografía simétrica de flujo:** La velocidad del flujo de datos es desconocida o se produce en ráfagas, como en telefonía o en las WLAN.
- **Criptografía simétrica de resumen:** funciones hash.

Problemas que presenta la criptografía secreta:

- La circulación de las claves: cómo conseguimos que el emisor y el receptor tengan la clave buena.
- La gestión de las claves almacenadas.

4. ALGORITMOS CRIPTOGRAFÍA SIMÉTRICA DE BLOQUE

DES y TDES

DES (Data Encryption Standard). Creado por IBM.

- Características:
 - Bloques de 64 bits.
 - Clave de 64 bits, de los cuales 8 bits son para la paridad.

Vulnerable a ataques de tipo criptoanálisis diferencial, pero se consiguió descifrar mediante fuerza bruta en 1998, y dejó de ser usado como standard.

TDES (Triple Data Encryption Standard). Sustituto del DES, cuando se consiguió romper.

- Características:
 - Las mismas que el anterior. Se refuerza en que aplica la encriptación tres veces con tres claves diferentes.

Sigue en uso en la actualidad, y se utiliza en los protocolos:

- IPSEC
- TLS/SSL
- Medios de pago
- Algunos productos Microsoft

KASUMI

Utilizado en 3GPP.

Sensible a ataques de criptoanálisis diferencial.

Fue diseñado por el grupo SAGE (Security Algorithms Group of Experts).

- Características:
 - Emplea el algoritmo MISTY1, pero con actualizaciones hardware.
 - Tamaño de bloque de 64 bits.
 - Tamaño de clave de 128 bits.
 - Algoritmo de tipo Cifrado Feistel con ocho vueltas y con una estructura recursiva.

BLOWFISH

Utilizado en IPSEC.

No se han encontrado técnicas de criptoanálisis efectivas contra el Blowfish.

Sin embargo, se ha dado más atención a la decodificación de bloques con bloques más grandes, como AES y Twofish.

AES

En 1996 el NIST publicó un concurso para reemplazar DES y TDES por un algoritmo que no fuese tan vulnerable como el DES, y fuese el nuevo estándar de cifrado avanzado (AES).

El ganador del concurso fue el algoritmo belga Rijndael.

- Características:
 - Matriz de sustitución y permutación.
 - Tamaño de bloque fijo de 128 bits.
 - Las longitudes de clave pueden ser de 128, 192 o 256 bits.

CAMELLIA

Desarrollado en Japón por la Corporación Telefónica y Telegráfica y la Corporación Eléctrica Mitsubishi, con prestaciones y seguridad equivalente al AES.

Se utiliza en TLS/SSL, tiene un tamaño de bloque de 128 bits y longitud de clave variable de 128, 192 y 256 bits.

Es junto AES, los sistemas de encriptación recomendados en la actualidad.

SEGURIDAD INFORMÁTICA Y CRIPTOGRAFÍA: TEMA 3

CRITOSISTEMAS SIMÉTRICOS DE CIFRADO EN FLUJO

1. Introducción

Criptografía simétrica de flujo

- ÚTIL POR SU VELOCIDAD Y SIMPLICIDAD.
- IMPLEMENTABLE EN HARDWARE
- GENERACIÓN DE UN FLUJO DE CLAVES A PARTIR DE UNA CLAVE CONOCIDA Y SEMILLA ALEATORIA, COMBINADA BIT A BIT CON LA INFORMACIÓN.
- PUEDEN SER SINCRONOS O AUTOSINCRONIZADOS.
- USADO EN DIFERENTES AMBITOS:
 - θ Aplicaciones software con elevado requisito de rendimiento.
 - θ Aplicaciones hardware con limitaciones de potencia o almacenamiento.

2. ALGORITMOS CRIPTOGRAFÍA SIMÉTRICA DE FLUJO

A5/1 Y A5/2

Diseñado para el cifrado de la comunicación entre terminales GSM.

- Características:
 - Organizado por secuencias de ráfagas, cada 4.615 mms y con 114 bits de información.
 - Basado en una combinación de 3 registros lineales de desplazamiento con retroalimentación.
 - Cada registro tiene un bit de reloj o sincronización.
 - Vulnerable a ataques de tipo ingeniería inversa.

RC4

Empleado en los protocolos WEP/WPA y SSL/TLS.

- Características:
 - Claves de hasta 256 bits, aunque la máxima seguridad se consigue ya con 40 bits.
 - Permutación de un vector S de 256 bits.
 - Tres fases:
 - Inicialización del vector de estado.
 - Generación del flujo de cifrado.
 - Mezcla del texto con el flujo de cifrado.
- Vulnerabilidades:
 - El primero de ellos se basa en patrones invariantes.
 - El segundo ataque describe la recuperación de la clave secreta.

E0

Implementado en la tecnología Bluetooth.

- Características:
 - Genera una secuencia de números pseudoaleatorios que se combina con el texto a encriptar mediante XOR.
 - Longitud de clave variable. El estándar es 128 bits.
 - Utiliza 4 registros lineales con desplazamiento.
 - Utiliza también una tabla de estados, de 3 bits de entrada y 2 de salida.
 - Por tanto precisa: Clave K de 128 bits y vector de 64 bits, que contiene la dirección lógica del master (48 bits) y un reloj (22 bits).
 - Dos fases:
 - Inicialización
 - Recursivo
- Vulnerabilidades: Ataques mediante fast correlation attack. Es posible reconstruir la clave si conocemos los 24 bits de la misma.

RABBIT

Incluido en ISO/IEC 18033-4. Es uno de los sistemas más eficientes y seguros. El tamaño de clave es de 128 bits.

- Características:
 - Generador de flujo de bit pseudoaleatorio con una clave de 128 bits, y un vector de inicialización de 64 bits.
 - Genera una corriente de bloques de 128 bits.
 - El cifrado se realiza mediante XOR tomando la salida del algoritmo y el mensaje.
 - El estado interno: 513 bits, dividido en 8 variables de estado de 32 bits y 8 variables de control de 32 bits.
 - El bit sobrante es un bit contador.

SNOW3G

El tamaño de clave es de 128 bits.

- Características:

- Generador de flujo de bit pseudoaleatorio con una clave de 128 bits.

SEGURIDAD INFORMÁTICA Y CRIPTOGRAFÍA: TEMA 4

CRITOSISTEMAS DE CLAVE PÚBLICA

1. Introducción

Criptografía de clave pública

- SISTEMAS CARACTERIZADOS POR EL USO DE UNA CLAVE PÚBLICA CONOCIDA POR TODOS Y OTRA PRIVADA.
- AMBAS CLAVES RELACIONADAS POR ALGORITMO MATEMÁTICO.
- EL RECEPTOR POSEE DOS CLAVES. PÚBLICA Y PRIVADA. EL EMISOR ENCRIPTA EL MENSAJE CON LA CLAVE PÚBLICA DEL RECEPTOR Y LO ENVIA. EL RECEPTOR DECODIFICA CON LA PRIVADA.

VENTAJAS

- NO SE PRECISA CANAL SEGURO
- NO HAY DESBORDAMIENTO EN EL TRATAMIENTO DE CLAVES Y CANALES.

INCONVENIENTES

- POCO EFICIENTE.
- ATAQUES CRIPTOGRAFICOS BASADOS EN EL ANALISIS DE LOS PAQUETES.
- NECESARIO PROTEGER LA CLAVE PRIVADA.
- NECESARIO TRANSPORTAR LA CLAVE PRIVADA.

FORMAS DE TRANSPORTAR LA CLAVE PRIVADA

- TARJETA DE MEMORIA.
- TARJETA PROCESADORA.
 - DE CONTACTO
 - SIN CONTACTO

2. Aplicaciones principales de la criptografía de clave pública

- Intercambio seguro

- Firma digital

3. Algoritmos de clave pública.

Diffie-Hellman.

- Dos interlocutores generen conjuntamente una clave compartida sin que un intruso lo detecte.
- Se basa en:
 - 2 números públicos y uno secreto.
 - Aplicación de un algoritmo.
 - Se intercambian el resultado de forma pública.
 - Se aplica otra fórmula matemática y obtienen una clave común.
- **Vulnerabilidades**
 - Pasivos: Si se obtuviese el número inventado de cualquiera de los miembros. Se descifra la clave.
 - Activo: Sensible a los ataques MITM (Man in the Middle).

RSA

- Se basa en el problema de factorización de números enteros grandes.
- Requiere alto grado de computación, por lo que poco éxito.
- Se basa en dos claves:
 - Clave pública.
 - Clave privada.
- Recomendaciones:
 - Claves de 2048 bits.
 - Uso de generadores aleatorios de números primos.

DSA

- Es un estándar del Gobierno Federal de los Estados Unidos de América para firmas digitales.
- Requiere más grado de computación que el RSA, por lo que únicamente se usa para firma de documentos.

ELGAMAL

- Basado en el algoritmo de Diffie-Hellman.
- Se utiliza para firmar y para cifrar/descifrar mensajes.
- Es de uso libre.
- Se basa en el cifrado/descifrado en grupos cíclicos.

SEGURIDAD INFORMÁTICA Y CRIPTOGRAFÍA: TEMA 5

FUNCIONES DE AUTENTICACIÓN E INTEGRIDAD

1. Introducción

AUTENTICACIÓN: Fundamental en la seguridad. Garantiza:

- Que el usuario que accede a un sistema es quien dice ser.
- Que el origen de un mensaje es quien dice ser.

Autenticar implica verificar que las credenciales presentadas por el usuario en la identificación corresponden a la identidad real de la persona.

¿Por qué es importante la autenticación?

- PRECEDE A LA AUTORIZACIÓN.

¿Y cómo se gestiona esa autorización?

- Mediante el CONTROL DE ACCESOS.

CONTROL DE ACCESOS

Método por el cual se incrementa la seguridad de una red mediante la restricción de uso de los recursos a los usuarios de la red de acuerdo a una política de seguridad definida.

Implementación a varios niveles.

- 1) Aplicación.
- 2) Middleware
- 3) Sistema Operativo
- 4) Hardware.

Existen dos políticas de control de acceso:

- Método de Control de acceso discrecional (DAC).
- Modelo de Control de acceso no discrecional o mandatorio (MAC)

Sistemas distribuidos: Necesario controlar usuarios y recursos empleados. Arquitectura AAA

- 1) Autenticación.
- 2) Autorización.
- 3) Trazabilidad (o auditoría).

2. Métodos y factores de Autenticación

- 1. Algo que el usuario sabe.**
- 2. Algo que el usuario tiene.**
- 3. Algo que el usuario es.**
- 4. Algo que el usuario suele hacer**

1) Algo que el usuario sabe

• Contraseñas

Es preciso implementar:

- Cambio de contraseñas con periodicidad.
- Chequeo de complejidad mínima.
- Teclados cambiantes para la inserción de las contraseñas.

• OTP (One time Password)

Contraseña que sólo puede utilizarse una vez, en una única sesión y posteriormente deja de tener validez.

2) Algo que el usuario tiene

• Certificados digitales

Basados en la posesión de una clave privada que garantiza la identidad mostrada en el certificado, sirven para la identificación y autenticación de los usuarios.

• Tarjetas Inteligentes

Chips criptográficos. Se clasifican en:

- Según su estructura:
 - Memoria.
 - Microprocesador.
 - Criptográficas.
- Según el interfaz:
 - Tarjetas de contacto.
 - Tarjeta sin contacto.
 - Tarjeta dual.

3) Algo que el usuario es

• Biométricos

Existen, con diferente fiabilidad, sistemas de autenticación biométrica sobre:

- Huellas dactilares.
- Reconocimiento facial.

- Voz.
- Aliento.
- Escritura.

Algunos ejemplos

- Para entrar en casa solamente nos hace falta una llave (algo que tienes). Pero en algunos países europeos los portales tienen un código (algo que sabes).
- Para entrar a un ordenador, generalmente necesitamos un usuario (algo que sabes) y una contraseña (algo que sabes).

3. Integridad. Funciones hash o resumen

FUNCION HASH O RESUMEN: Fundamental en la criptografía, sobre todo en la integridad de los mensajes.

ENTRADA: Mensaje de longitud variable:

SALIDA: Serie de bits o HASH de longitud fija, que forma la huella digital de la entrada.

Propiedades de la huella digital HASH:

- Compresión.
- Difusión.
- Resistencia a la preimagen.
- Resistencia a la segunda preimagen.
- Resistencia fuerte a la colisión.

Modos de operación fundamentales en los algoritmos HASH:

- MDC: Se usan en la verificación de integridad de mensajes.
- MAC: Funciones hash que adicionalmente utiliza una clave compartida entre emisor y receptor para calcular el hash, y que permite comprobar tanto la integridad como la autenticidad del origen del mensaje.

Algoritmos HASH

MD5

Algoritmos de reducción criptográficos diseñados por el profesor Ronald Rivest del MIT. Fue desarrollado en 1991 como reemplazo del algoritmo MD4

RIPEMD

RIPEMD-160 es un algoritmo del resumen del mensaje de 160 bits desarrollado en Europa.

1. Trabaja con palabras de 32 bits.

2. En cuanto a las operaciones que emplea, tenemos:

- Rotación a la izquierda
- Operaciones booleanas (AND, NOT, OR y XOR).
- Operaciones complementarias de adición de palabras módulo 232.

SHA

El SHA (Algoritmo de Hash Seguro) es una familia de funciones hash de cifrado publicadas por el NIST.

La primera versión del algoritmo fue creada en 1993 con el nombre de SHA, aunque en la actualidad se la conoce como SHA-0 para evitar confusiones con las versiones posteriores. La segunda versión del sistema, SHA-1, fue publicada dos años más tarde.

Produce una salida de 160 bits.

WHIRLPOOL

WHIRLPOOL es una función de hash que consiste en una construcción Miyaguchi-Preneel basada en una modificación AES. Dado un mensaje de un tamaño menor de 2256 bits, devuelve un hash de 512 bits.

Los autores han declarado que WHIRLPOOL no está patentado (ni lo estará). Puede ser usado libremente para cualquier propósito.

SEGURIDAD INFORMÁTICA Y CRIPTOGRAFÍA: TEMA 6

FIRMA DIGITAL Y CERTIFICADOS DIGITALES

1. Introducción

Firma digital: Mecanismo criptográfico que permite al receptor de un mensaje firmado digitalmente identificar a la entidad originadora de dicho mensaje y confirmar que el mensaje no ha sido alterado desde que fue firmado por el originador.

Certificado digital: Documento electrónico firmado digitalmente que tienen como función fundamental vincular al poseedor de una clave privada con su clave pública.

2. Firma digitalizada y firma electrónica.

Firma electrónica: La firma electrónica es un concepto jurídico donde una persona acepta el contenido de un mensaje electrónico a través de cualquier medio electrónico válido.

Tipos:

- Firma electrónica simple (EJ: Usuario/contraseña).
- Firma electrónica avanzada (EJ: Firma digital recogida a través de un dispositivo, con sellado de tiempo y metadatos asociados).
- Firma electrónica reconocida o cualificada (EJ: DNI electrónico).

Firma Digitalizada: La firma digitalizada es un tipo de firma que permite identificar al firmante en un documento electrónico incluyendo el aspecto gráfico de la firma manuscrita. Puede ser:

- Firma electrónica simple.
- Firma electrónica avanzada.

3. Firma digital.

La **firma digital** es un mecanismo de encriptación y por tanto es necesario tener:

- Un algoritmo de generación de firma digital.
- Un algoritmo de verificación de firma digital.
- Un esquema o mecanismo de firma digital consistente en un algoritmo de generación de firma y su algoritmo de verificación asociado.
- Un proceso o procedimiento de firma digital

Las firmas digitales han de ser:

- Únicas
- Infalsificables
- Verificables
- Innegables
- Viables

Formatos de Firma digital:

- PKCS#7/CMS
- CAdES
- Firma XML
- PAdES
- ASiC

PKCS#7/CMS

- Definido por RSA, dentro la serie PKCS.
- El formato está codificado en ASN.1 (información en binario).
- Fue la base para el estándar S/MIME y para CMS.

Formatos de mensajes definidos en PKCS#7:

- data: envío de datos sin cifrar.
- signed data: datos firmados, usado para autenticación del remitente.
- signed-and-enveloped data: datos firmados y encapsulados. Para autenticidad y confidencialidad.
- digested data: hash de los datos, para comprobación de la integridad del mensaje.
- encrypted data: datos cifrados, utilizados para confidencialidad.

CAdES

- CAdES-BES: Firma básica.
- CAdES-EPES: Firma basada en política explícita.
- CAdES-A Firma de archivo.

Firma XML

XMLSIG. Define una sintaxis XML para soporte de la firma digital.

Tipos:

- Enveloped Signature
- Detached Signature
- Enveloping Signature

XAdES. Perfiles XMLDSig para ser usados con firma electrónica avanzada.

- XAdES-BES: Firma básica.
- XAdES-EPES: Firma basada en política explícita.
- XAdES-A: Firma de archivo.

PAdES

Perfiles para el uso de la firma electrónica avanzada con documentos PDF.

Tipos:

- PAdES-BES: Perfil de firma PDF avanzada basada en CAdESBES e incorpora opción de incluir en la firma un sello de tiempo.
- PAdES-EPES: Perfil de firma PDF avanzada basada en CAdESEPEs.
- PAdES-LTV Profile: Es el formato de firma longeva.

ASiC

Especifica el uso de estructuras de contenedor que engloba en un solo perfil:

- Firmas
- Sellos de tiempo junto a los archivos u objetos firmados.

El contenedor del paquete utiliza un formato basado en ZIP.

4. Certificados Digitales

En la comunicación segura entre cliente y servidor aparecen nuevos interlocutores:

- La Autoridad de Certificación.
- La Autoridad de Registro.
- La Autoridad de Validación.
- Los repositorios.

Marco de autenticación X.509

X.509v3 es el estándar de la ITU-T para infraestructuras de claves públicas.

X.509 especifica la estructura y formato de certificados de clave pública, listas de revocación de certificados, certificados de atributos y un algoritmo de validación de la ruta de certificación.

Comprobación de firmas y certificados digitales

- CERTIFICATE REVOCATION LIST (CRL)
- ONLINE CERTIFICATE STATUS PROTOCOL

5. Tipos de certificados.

- En función del titular:
 - Certificado de persona física
 - Certificado de persona jurídica.
 - Certificado de entidad sin personalidad jurídica.
- En función del tipo de certificado:
 - Certificados reconocidos.
 - Certificados no reconocidos.
- Certificados regulados por la ley 11/2007.

- Certificado de sede electrónica.
- Certificado de sello de actuación administrativa automatizada.
- Certificado de empleado público.
- Certificados regulados por el Reglamento UE 910/2014:
 - Certificado de firma electrónica
 - Certificado de sello electrónico.
 - Certificado de autenticación de sitio web.
- Certificados cualificados de sello electrónico.
- Certificados cualificados de autenticación de sitios web.

6. Ejemplo de PKI. El DNI electrónico.

Contiene:

- Datos generales de la persona, los mismos que están impresos en la tarjeta.
- Datos biométricos de la persona, como su huella dactilar digitalizada.
- Claves de cifrado asimétrico.

SEGURIDAD INFORMÁTICA Y CRIPTOGRAFÍA: TEMA 7

APLICACIONES SEGURAS

1. Introducción

Principal objetivo de los ataques: Capa de Aplicación.

Seguridad:

- Confidencialidad.
- Integridad
- Disponibilidad

2. Identificación de los requisitos de Seguridad.

Estándar: Common Criteria o CC.

Dos tipos de documentos:

- Perfil de protección.
- Objetivo de Seguridad.

Pasos:

- 1) Identificar el entorno.
- 2) Establecer supuestos sobre el entorno.
- 3) Lista de posibles amenazas.
- 4) Descripción de la política de seguridad de la organización.
- 5) Definición de los objetivos de seguridad.

Requisitos funcionales de una aplicación para un CC:

- Auditoría de Seguridad.
- Protección de datos de usuario.
- Gestión de seguridad.
- Privacidad.
- Autodefensa.
- Control de acceso.

3. Hitos en la Seguridad del Software.

3.1 Code Review: El code review o revisión de código consiste en el examen sistemático del código fuente de un programa informático.

Objetivos:

- Mejorar la calidad del código.
- Mejorar las cualidades de los desarrolladores.

Metodologías:

- Metodología AGIL (SCRUM).
- Revisiones periódicas de código

3.2 Análisis de Riesgos en la arquitectura

La arquitectura del producto software es uno de los aspectos más importantes en el desarrollo software.

IMPRESINDIBLE realizar actividades de verificación de la misma, para identificar problemas que podría resultar muy costoso eliminar posteriormente.

OBJETIVO: La verificación del diseño.

CONSECUENCIAS DE UN MAL ANALISIS:

- Sistemas que no cubren las expectativas de los clientes y de la organización de desarrollo.
- Alto costo la corrección de los defectos A POSTERIORI.

Técnicas de Evaluación:

- Checklist y cuestionarios.
- Evaluación basada en escenarios para cuestionar al arquitecto sobre las decisiones de diseño que tomó.
- Otras

3.3 Test de penetración

El test de penetración, o "pentest", es un ataque a un sistema informático con la intención de encontrar las debilidades de seguridad y todo lo que podría tener acceso a ella.

- Caja Blanca
- Caja Negra

Ventajas

- Determinar la posibilidad de éxito de un ataque.
- Identificación de vulnerabilidades de alto riesgo.
- Identificación de vulnerabilidades que pueden ser difíciles o imposibles de detectar.
- Comprobar la capacidad de los defensores de la red para detectar con éxito y responder a los ataques.

Procesos de pruebas de penetración

- El descubrimiento de una combinación de operaciones legales que le permitirá ejecutar una operación ilegal. Dos tipos:
 - o Metasploit.
 - o Fuzzing.
- La operación ilegal:
 - o controlador de ratón remoto.
 - o webcam peeker.
 - o ladrón de contraseñas hash.

3.4 Test de seguridad basada en los riesgos

Enfoque basado en el riesgo de la información, para determinar las pruebas de seguridad del software corporativo.

Es imposible probar todo el software. Confiar en los proveedores.

Esto permitirá a las organizaciones centrar sus esfuerzos en el software para:

- Hacer el mejor uso de los recursos.
- Garantizar que las pruebas elegidas resaltan las deficiencias.

Con los resultados de la evaluación del riesgo, se seleccionan las pruebas más adecuadas.

3.5. Casos de abuso

Caso de abuso: Tipo de interacción completa entre un sistema y uno o más actores, donde el resultado de la interacción es perjudicial para el sistema, uno de los actores o una de las partes interesadas del sistema.

3.6. Requerimientos de seguridad

- Arquitectura de la aplicación.
- Plataforma donde correrá la aplicación.
- Tipo de conectividad.
- Tipos de datos que se almacenan o transmiten
- Tipos de registro que el sistema debe generar.

3.6.1. Recomendaciones de seguridad

- Principio del menor privilegio.
 - o Validar SIEMPRE los valores de entrada.
 - o Proteger de archivos de configuración y registro.
 - o Restringir archivos de salida.
 - o Utilizar manejo de sesiones seguro.
- Arquitectura de la aplicación.
 - o Reducción de la superficie de ataque.

- Defensa en profundidad.
 - Manejo seguro de mensajes de error
- Mecanismo de autenticación de usuarios.
 - Algo que sabes.
 - Algo que tienes.
 - Algo que eres.
- Administración de usuarios.
 - El nombre del usuario.
 - Convenio de nombres.
- Administración de contraseñas.
 - La confidencialidad de la contraseña.
 - La resistencia de adivinar la contraseña.
 - La resistencia de la contraseña ante un ataque de fuerza bruta.
- Encriptación.
 - Definir algoritmo de encriptación.
 - Definir “granularidad” de la encriptación.
 - NUNCA colocar la clave en el código.
 - Considerar encriptación de claves de encriptación.
- Manejo de información sensible.
 - Almacenamiento protegido
 - Encriptación de los datos
 - Hashes
 - Transmisión segura
 - Borrado de datos
- Transmisiones. Interacción de la aplicación.
 - Interacción con Firewalls
 - Interacción con dispositivos
 - Interacción con Bases de Datos
 - Interfaces con otros sistemas
- Registro de eventos.
 - Definición de la estructura de la información a almacenar.
 - Lugar donde almacenar esa información.
 - Identificación de la información más importante.

3.7. Análisis externo

Consiste en la identificación y evaluación de acontecimientos, cambios y tendencias que suceden en el entorno de una empresa y que están más allá de su control.

Objetivos:

- El análisis de la eficiencia de los Sistemas Informáticos
- La verificación del cumplimiento de la Normativa
- La revisión de la gestión de los recursos informáticos.

Tipos de auditorías:

- Auditoría de los datos.
- Auditoría de las bases de datos.
- Auditoría de la seguridad.
- Auditoría de la seguridad física.

- Auditoría de la seguridad lógica.

4. Errores frecuentes de codificación.

- Validación de la entrada y codificación.
- Abusos de la API.
- Funcionalidad de seguridad.
- Manejo de errores.

Calidad del código. Errores comunes.

- División por cero
- Ciclo infinito
- Exceder el tamaño del array
- Utilizar una variable no inicializada
- Desbordamiento de búfer

Encapsulamiento

Conocida como programación orientada a objetos.

Problemas:

- Limitaciones para el programador.
- Tamaño excesivo de las aplicaciones resultantes.
- Velocidad de ejecución.

5. Aplicaciones Web.

Importante realizar un esfuerzo para asegurar que la información y los recursos están protegidos.

Puntos a tener en cuenta:

- Disponibilidad.
- Autenticidad.
- Integridad.
- Confidencialidad.
- Trazabilidad.

5.1 Autenticación/Autorización.

Diseño de autenticación. Elegir entre:

- Autenticación local vs. autenticación externa.
- Tipos de autenticación.
- Factores de autenticación.
 - Por lo que sabe.
 - Por lo que se tiene.
 - Por lo que se es.
- Usuarios y contraseñas por defecto.
- Nivel de acceso de los usuarios por defecto.
- Bloqueo de cuentas vs. Captcha.

Diseño de la autorización.

- Definición de niveles de acceso.
- Funciones que puede ejecutar cada nivel.
- Datos que puede leer / escribir / modificar cada nivel.
- Asignación de niveles propia o integrada.
- Roles / grupos definidos localmente.

5.2 Manejo de sesiones.

Técnica que vincula información a un usuario en concreto durante el proceso de visita a una web.

- Cookies y sesiones.
 - Mantener opciones de visualización.
 - Almacenar variables.
 - Realizar un seguimiento de la actividad de los usuarios.
 - Autenticación.
- Cookies de sesión.
 - La única información que debe contener será el identificador de la sesión.
 - El identificador de sesión debe ser único, aleatorio y no predecible.
 - Las variables almacenadas en la sesión, deben permanecer lo más protegidas posible del exterior.
 - Cuando el usuario ha terminado su actividad o ha transcurrido un periodo de tiempo, la sesión debe borrarse.

5.3 Prácticas básicas de seguridad web.

- Balancear riesgo y usabilidad.
- Rastrear el paso de los datos.
- Filtrar entradas.
- Escapado de salidas.

5.4 Clasificación de los ataques web.

- Ataques URL de tipo semántico.
- Ataques de Cross-site Scripting.
- Ataques de Cross-Site Request Forgery.
- Peticiones HTTP falsificadas.